

Chapter 13

Controls

Physical and Technical Controls

Physical controls block
physical access

- Locked door
- Closed gate

Technical controls are electronic
Computer-related controls
are technical

Administrative Controls

Policies and procedures

Set by administrators
or managers

Organizational decisions put
in place

Govern expected actions

Deterrent Preventative and Detective Controls

Deterrent signals expected behavior

Preventive blocks unwanted actions

Detective reviews what occurred
Used before or after an event

Responsive and Corrective Controls

Responsive drives
remediation actions

Used after an incident happens

Corrective restores normal state

Helps put things back as before

Retail Deterrent Controls

Visible signs discourage behavior

Prominent screens or cameras
in view

Signal monitoring is in place

Intended to make
shoplifters hesitate

Retail Preventative Controls

Stop theft before it occurs

- Locked cages
- Secure product locks

Loss prevention officer presence

Designed to prevent shoplifting

Retail Detective Controls

Detect theft activity

Security cameras
monitor movement

Beeping alarms indicate product
removal

Evidence after the event

Retail Responsive and Corrective Controls

Responsive actions after theft

- Intercept shoplifter
- Issue trespass warning

Police involvement as response

Corrective restores item or
records loss

Compensating Controls

Added when a control
is insufficient

Layered to reduce remaining risk

Compensate for control shortfalls

MFA can strengthen passwords

Controls Can Serve Multiple Purposes

Control types are not exclusive

One control may serve multiple functions

Security camera example

- Deterrent and detective

Purpose depends on use

Chapter 13

Risk

Risk Mitigation

Reduce likelihood of threats
Implement security controls
Use policies and procedures
Apply technical solutions

Risk Transference

Shift risk to another party

Typically involves cost

Use third-party services

Example

- MSSP outsourcing

Risk Avoidance

Eliminate exposure to risk

Avoid risky activities

Do not deploy vulnerable systems

Prevent risk entirely

Risk Acceptance

Accept risk level

May be low impact or likelihood

Controls may be too costly

Organization chooses to proceed

Inherent and Residual Risk

Inherent risk before controls

Residual risk after controls

Some risk always remains

Cannot eliminate all threats

Risk Appetite

Amount of risk accepted

Defines tolerance threshold

Guides decision making

Determines security level